Vulnerability Assessment Report

Target: http://zero.webappsecurity.com
Prepared by: Kareem Badran
Date: 6th April 2026

Executive Summary

This report presents the results of a passive vulnerability assessment conducted on the Zero Web Application Security demo website. The purpose of this assessment was to identify common security weaknesses using non-intrusive techniques and provide practical recommendations to improve the overall security posture of the application.
The assessment identified several medium and low-risk vulnerabilities related to insecure communication, missing security controls, and information exposure.

Scope

- Target: http://zero.webappsecurity.com
- Assessment Type: Passive (read-only) vulnerability assessment
- Testing Approach: Non-intrusive analysis only

Methodology

The assessment was conducted using a combination of automated tools and manual inspection techniques:

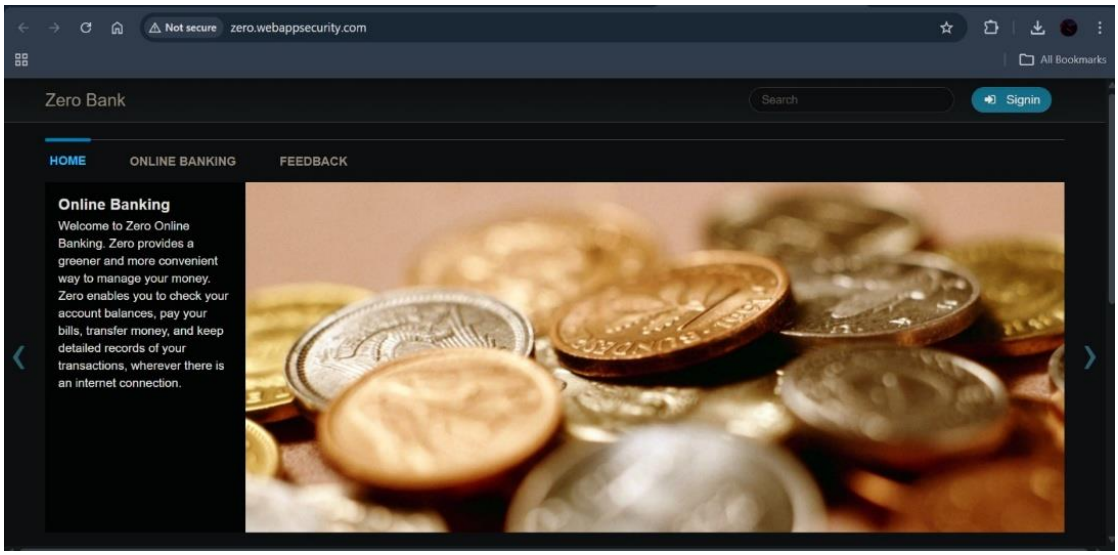
- Nmap was used to identify open ports and running services
- Browser Developer Tools were used to analyze HTTP requests and response headers
- OWASP ZAP (Passive Mode) was used to identify vulnerabilities without active exploitation

All testing was conducted in a safe, read-only manner without attempting to exploit any vulnerabilities.

Findings
Insecure HTTP Connection

Risk Level: Medium

📸 *Browser showing "Not Secure" HTTP connection*



Description:
The application is accessible over HTTP rather than HTTPS, meaning that communication between the client and server is not encrypted.

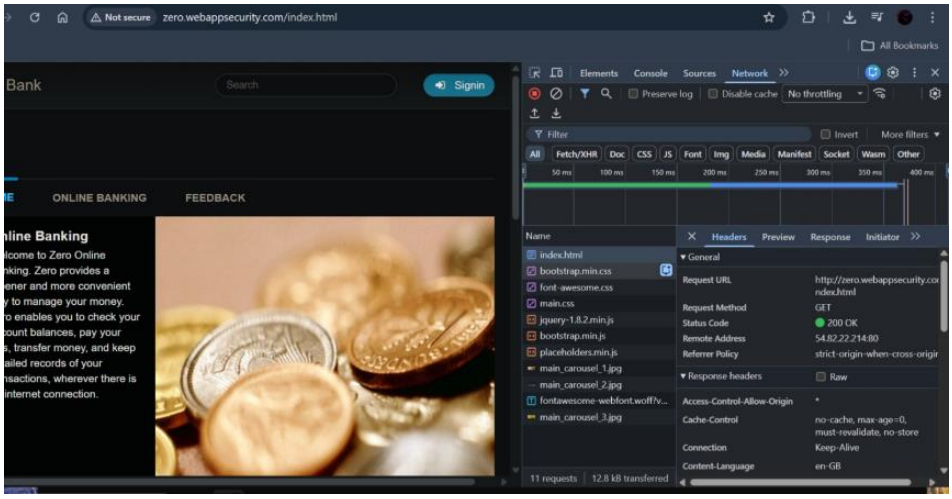
Impact:
Unencrypted communication can allow attackers to intercept sensitive data transmitted between users and the application.

Recommendation:
Implement HTTPS using SSL/TLS certificates and enforce redirection from HTTP to HTTPS.

Missing Security Headers

Risk Level: Medium

📷 *Missing security headers in Browser DevTools / ZAP*



Description:
The application does not implement important HTTP security headers such as Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options.

Impact:
Missing security headers increases the risk of attacks such as clickjacking, MIME-type attacks, and cross-site scripting.

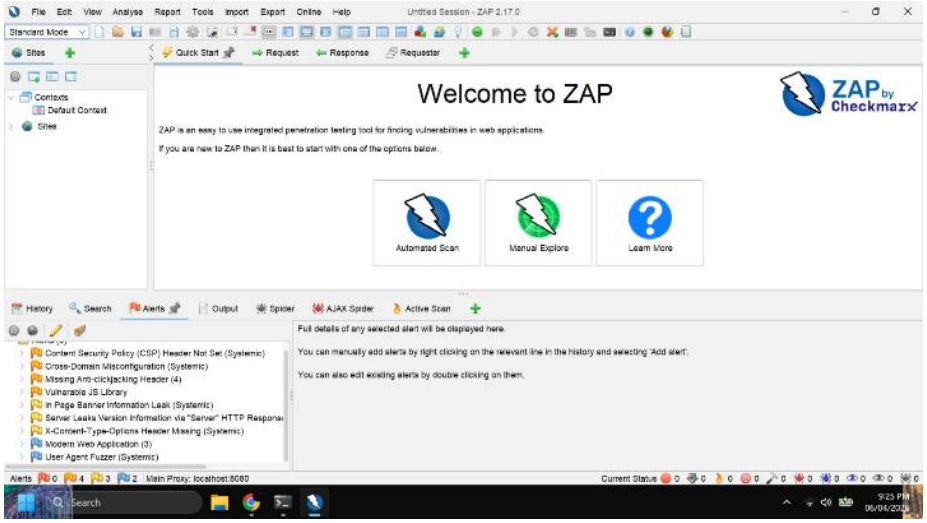
Recommendation:
Implement the following security headers:

- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options

Information Disclosure

Risk Level: Medium

📸 *ZAP alert showing server information disclosure*



Description:
The application reveals server-related information in HTTP responses.

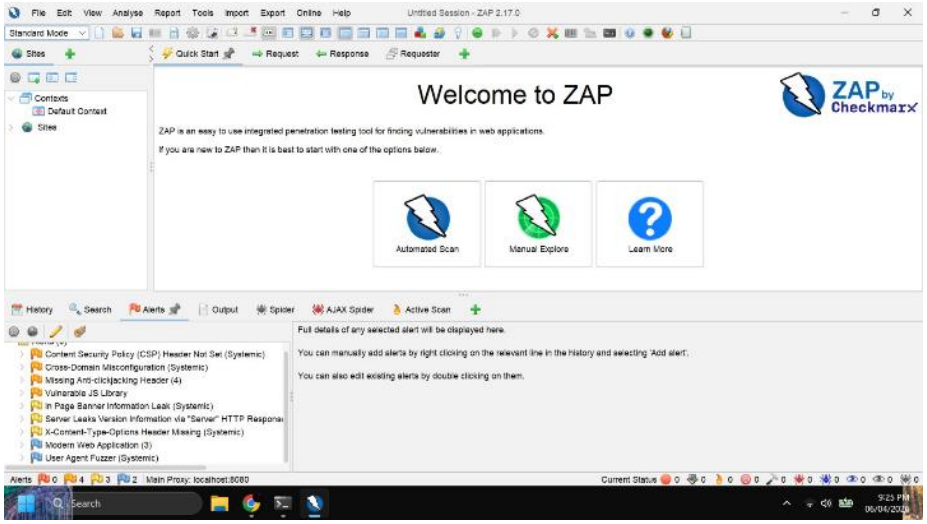
Impact:
Attackers can use this information to identify underlying technologies and plan targeted attacks.

Recommendation:
Disable or restrict server version information in HTTP headers.

Vulnerable JavaScript Library

Risk Level: Medium

📷 *OWASP ZAP alert highlighting vulnerable JavaScript library*



Description:
The application uses outdated or potentially vulnerable JavaScript libraries, as identified by OWASP ZAP during the passive scan.

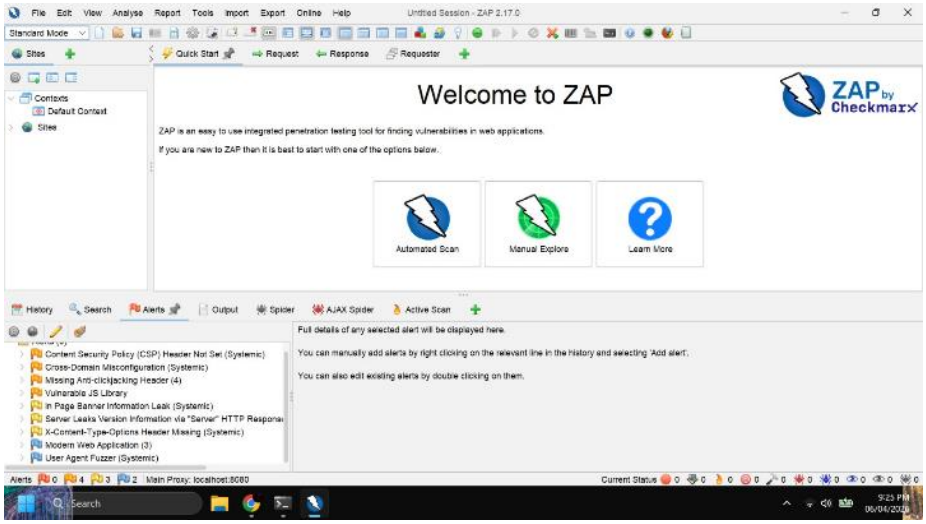
Impact:
Outdated JavaScript libraries may contain known security vulnerabilities that attackers can exploit to compromise the application.

Recommendation:
Update all JavaScript libraries to the latest secure versions and regularly monitor for known vulnerabilities.

Information Leakage

Risk Level: Low

📷 *OWASP ZAP alert showing information leakage*



Description:
The application exposes additional information through HTTP responses and page content, which may reveal details about the system.

Impact:
This information can assist attackers during the reconnaissance phase and help them identify potential attack vectors.

Recommendation:
Limit the amount of information exposed in responses and remove unnecessary details from the application.

Conclusion

The passive vulnerability assessment identified several common security issues affecting the application. While none of the findings indicate immediate critical risk, addressing these vulnerabilities will significantly improve the application's security posture.
Implementing HTTPS, adding proper security headers, reducing information exposure, and updating outdated components are recommended as priority actions.